Secured Finance Incident - Technical Interim Report

On-chain data current as of 2026-09-09/10 (UTC).

> On-chain figures below are derived directly from on-chain data or the deployed contract source, verified on-chain or reproduced. Statements about recoverability, exchange records, or legal process are inferences or recommendations, not on-chain facts. Long transaction hashes and addresses are shown in full for verification.

Overview

Between **2026-09-05 22:11 and 2026-09-06 18:01 UTC**, an order-book accounting flaw let attackers be paid out for lend orders that never filled: a still-resting order was misclassified as filled and credited unbacked future value, so the same collateral was counted twice and could be withdrawn. Roughly **$176,200** in protocol funds was taken across Ethereum, Arbitrum and Filecoin in about fifteen transactions by **six attacker addresses in five apparently independent clusters** - including two independent implementations of the same undisclosed bug deployed about 75 minutes apart. All vaults were **paused on 2026-09-07 (07:55 UTC Ethereum, 08:01 Arbitrum)**, which contains the incident but does not remediate it.

Status: root-cause analysis and fund tracing are complete and the protocol is paused; the fix commit exists but is not yet deployed; the remediation in section 4 is planned and not yet executed.

1. Root cause

A single defect: a red-black tree rebalancing error in the order book library `OrderStatisticsTreeLib`.

Order classification is derived from tree reachability: `isActiveOrderId(v,id) = orderIdExists(v,id) && exists(v)`, where `exists(v)` walks parent pointers up to the root. During a bounded `dropRight` (the order-matching sweep that consumes crossed orders from the book), a faulty `rotateTreeToRight` detaches a still-live order's subtree (the node ends with `parent == 0` while not being the root), so `exists(v)` returns false for an order that is still physically resting. That order is then classified as filled; settlement (`cleanUpFunds`, the protocol's deferred-settlement routine) mints future value to the lender with **no matching borrower obligation**. The same collateral is counted twice.

Verification

- **Deterministic reproduction.** A library-level model orphans a modeled-live order at unit price 2 (the attack's payload price; unit price is a 0-10,000 scale where 10,000 is par, so a price of 2 implies a near-zero price and therefore an outsized future value) on the deployed code, and orphans zero live orders under fix commit `5bb5128` across the search space.
- **Mainnet-fork replay of the real attack.** Replaying the attacker's own contract against a fork: on the live libraries the vault loses **3000.000002 USDC** (`getTotalDeposit("USDC")` 19001.286568 → 16001.286566), matching the incident; with `5bb5128` etched into the two logic libraries the call **reverts** at `"lend target active"` with **0 outflow**.
- **Location.** The tree is inlined into the two logic libraries the market delegatecalls - `OrderActionLogic` `0x41eb72013fD9B65fB9b9bBfA36894ca3a630750B` and `OrderBookLogic` `0x05e71DC39C3De40e017D166e605b97451E7f21B5` - not the market implementation `0xD06dd40Ba7c2cff3a6Aa2f59C55d249AcA57E521`, which is byte-identical under the patch.

Two design behaviors were examined and found **correct, not defects**: lazy (deferred) settlement, and crediting a filled order at the maker's own limit price (`futureValue = amount × 10000 / unitPrice` is the same formula a genuine fill uses). The fix commit `5bb5128` addresses the rebalancing trigger but is **not deployed on any live branch**.

2. Impact

Realized **protocol loss** within the assessed scope is approximately **$176,200**, across Ethereum, Arbitrum and Filecoin, executed through roughly fifteen transactions by several independent actors. A further $4,660 iFIL position was liquidated on Filecoin; that is a borrower's loss, not a loss to the protocol, and is listed separately below. The incident is currently **contained by pause, not remediated**.

CHAIN (ASSETS)	REALIZED LOSS
Ethereum (USDC, WBTC, WETH, JPYC)	$131,820
Arbitrum (USDC, WETH, WBTC)	$8,944
Filecoin (USDFC, WFIL)	$35,432
Total protocol loss	**~$176,196**

Transaction T15 used the same defect to liquidate a protocol user and seize ~$4,660 of iFIL; that loss fell on the liquidated user, not the protocol, and is excluded from the totals.

The erroneous ledger state is still present on-chain (protocol paused). Read directly from each `FutureValueVault` via `getTotalLendingSupply` / `getTotalBorrowingSupply` (future value, FV; a healthy market has lender FV == borrower FV per maturity, each figure in that market's own token):

MARKET (FUTUREVALUEVAULT)	TOTAL LEND FV	TOTAL BORROW FV	LEND : BORROW
ETH `0x381c2ad69bbe7c5abd09e73036480aab51cdee6c`	33.391615	0.016969	**~1,968x**
USDC `0xf7c27a7c5b33933880ce8f4054c4d340020181b2`	2,507,561	38.96	**~64,358x**
WBTC `0x688c8dcbe51032baa72758a7ae54a1d29fbaa99c`	1.513640	0.001512	**~1,000x**

The ETH imbalance is concentrated in specific maturities (e.g. 1813881600 = 2027-06-25: 8.32 ETH; 1845936000 = 2028-06-30: 24.19 ETH). This unpaired lender future value is the on-chain signature of the phantom mint and is what remediation must clear. Totals are summed over each market's current active maturities (`getMaturities`); WBTC's borrower total is near zero, so its ratio is order-of-magnitude only. The markets shown are on Ethereum, which holds the bulk of the standing exposure; the Arbitrum and Filecoin markets carry additional imbalances of the same kind on a smaller scale, consistent with their smaller per-chain loss above.

Poisoned on-chain state

Beyond the realized loss, the protocol's stored state is left **poisoned** and cannot safely resume as-is. Three artifacts persist on-chain: (1) **unpaired lender future value** - the phantom lender claims above, roughly **2.51M USDC, 33.4 ETH and 1.51 WBTC (on the order of $2.6M)** with no matching borrower obligation, payable from real collateral at maturity; this standing exposure is far larger than the ~$176,200 protocol loss and is the reason the protocol is paused rather than remediated; (2) **orphaned order-book nodes** that the faulty rebalancing detached and left inert in tree storage; and (3) a **latent hazard** - because settled inactive orders are not deleted from storage, the cancel path can still reach a detached node and overwrite the order-book root. The state must be corrected before the protocol is unpaused.

3. Fund tracing

Value was extracted from the protocol vault, converted, and dispersed across several independent actor clusters and multiple chains. Destinations by disposition:

TERMINAL	AMOUNT	~USD	DISPOSITION
Block builder treasury (builder.ultrasound.money)	31.55 ETH (net)	~$78,500	**29.9823 ETH returned to a protocol recovery address 2026-09-10; ~1.57 ETH kept as builder fee (see 3.1)**
Operator wallet `0xf601d7646c2db4940f0b1909b4835ed7279c5aed`	16,001.07 DAI	~$16,000	**Traced; currently unmoved**
Operator wallet `0x3196398321d77a2511d369dcb6eca9d2ad87b73a`	~2.13 ETH	~$5,308	Exploit-attributable portion, traced and unmoved; wallet now holds 8.22 ETH incl. non-exploit funds
Exchange leg (FixedFloat)	4.8395 ETH	~$12,000	On-chain deposit identified; payout held only in exchange records (see 3.2)
Mayan bridge to BNB Chain	6.39 ETH	~$15,400	Resolved one chain onward; hands off at exchange
Tornado Cash	~20.1 ETH	~$50,000	**Not recoverable (mixer)**
Validators (in-block)	1.77 ETH	~$4,400	**Consumed as block reward (part of the builder gross above)**

Traced to known, currently-unmoved addresses: approximately **$23,600** (chiefly the unmoved DAI position); separately, **29.9823 ETH (~$74,600) of the builder-routed value has since been returned to the protocol** (2026-09-10, see 3.1). This table shows the current disposition of traced value (balances at 2026-09-09 prices), not an exact partition of the ~$176,200 protocol loss removed at extraction; the validator line is part of the builder gross, not additive to it.

3.1 Block-builder route

Two exploit bundles paid the builder fee recipient `0x6c42a0b5d13059fa36d5567ab04f83bab57bbf0e` (identity confirmed: the `extraData` of blocks 25914192 and 25914488 both decode to "builder.ultrasound.money"). The value provably originated from the theft - both txs call the Secured Finance `TokenVault` and `LendingMarketController` and drain the vault before paying the builder.

LEG	TRANSACTION	ETH
Bundle 1 → builder (gross)	`0xcd6159860783d8d481cc4bf4dceddc88acdca6bb08f6445525b2904cfd75b1da`	28.837210715286011136
Bundle 2 → builder (gross)	`0x4b3c70d0327cec387ec03169d63d85bea964f3bf791fc2f34f76ad663d684c3d`	4.487755000000000000
Builder → validator	`0x1713e246af0e1dd55e57ad3e3c997cabfb67f7fb75a0fe658f3fb8b2d50915bf`	1.278613875829206116
Builder → validator	`0x948274de3447fde02549959167149e4893b13bed1780e387ec7b49178a9f180e`	0.491623832593168696

Gross received 33.324966 ETH; net retained 31.554728 ETH (gross minus the 1.770238 ETH forwarded to validators, which is unrecovered). The routing was performed by a third-party MEV searcher (`c0ffeebabe.eth` , bot `0xe08d97e151473a848c3d9ca3f323cb720472d015`), which retained only ~0.0138 ETH; the builder received the remainder as a standard bundle bid, and on-chain data shows no interaction between the builder address and the exploit contracts beyond receipt of the bid.

Returned (2026-09-10). The builder returned **29.9823 ETH** (~$74,600) of the retained value to a protocol recovery address `0x5903780e97c7b52bb662fe755de4e5fba7652622` , in tx `0xc626bcfaccfac6b437ee395e5335f1b323c18d463ca52b63b691d3f167cf489d` (20:14 UTC). That leaves **~1.5724 ETH** (~$3,900; net retained 31.554728 minus 29.9823) with the builder as its fee; the 1.770238 ETH paid to validators is separate and unrecovered.

3.2 Exchange leg (FixedFloat)

Path: the deBridge hop `0x290A3DF4c40d948D4E2953EaefC82cd580Ae0304` (Arbitrum) → single-use deposit address `0x44210a25ea971b609a2d409941a80061efda977e` → exchange hot wallet `0xf6ee635c28dda95a74ba989807000cbe00317d27`; 4.8395 ETH, all within ~4 minutes, funding tx `0xaf4073812476fbebe79b646722d4e61a1567f5a3ed33638a6e9a689edc31f078`. The payout destination is held only in exchange records and would require a request to the exchange (e.g. via law enforcement) to obtain.

4. Remediation

Remediation has two parts: deploy the fixed logic so the defect cannot recur, then correct the poisoned state described in section 2 by rebalancing the ledger - synthesise the missing borrower-side positions and fund the deposit shortfall. This is consistent with the protocol's design and needs **no** structural repair of the order-book tree: settlement clears inactive orders (`_cleanLendOrders` , the lend-order step of the `cleanUpFunds` routine) by pruning the user's order-id list and summing future value, with no tree `remove()` and no rebalancing, so detached nodes are inert, unreferenced storage. The table below states each defect in the current state and the exact action it requires; the verification gate that follows must pass before the protocol is unpaused.

- **Vulnerable code is live.** The deployed market logic is still the buggy tree; the fix commit `5bb5128` is not deployed on any live branch, so reopening as-is leaves the root cause exploitable.
  Action: deploy the fixed logic via the shared beacon (the upgrade proxy all markets point to) so no new orphaning can occur, before or as part of reopening.
- **Poisoned ledger: unpaired future value.** Lender future value is recorded with no matching borrower obligation (the imbalance in section 2: ETH ~1,968x, USDC ~64,358x); the books do not conserve.
  Action: create the missing borrower-side positions and fund the deposit shortfall so that lender FV == borrower FV per maturity. Offset the **current** on-chain net per user and maturity, not the original transaction amounts - over-offsetting silently flips a maturity into a phantom borrow (FV balances are signed and `decrease()` does not floor at zero). Assert each maturity returns to balanced.
- **Value that already left the vault.** Phantom value withdrawn as tokenised positions (ZC tokens - zero-coupon tokens, the transferable claim on a position - are deployed for the affected maturities) or rolled into genesis value (the protocol's cross-maturity carried balance) is not reached by a vault future-value offset; those claims survive.
  Action: reconcile ZC-token supply against backing and reconcile genesis value. Assert the attacker's net position and deposit are zero and non-withdrawable so that funding the correction does not hand the attacker a balance.
- **Latent cancel hazard.** Settled inactive orders are not deleted from storage (`self.orders[id]` is deleted only on the cancel path), so `cancelOrder` can still reach a detached node, whose removal executes `self.root = probe` and overwrites the order-book root.
  Action: in the permanent fix, delete or guard settled order records, or gate cancellation on active status. Not triggered by the remediation itself, but close it before reopening.

Recovery follow-up. The FixedFloat leg (~4.8395 ETH) currently ends on-chain at the exchange deposit. Once the exchange provides the payout (withdrawal) address on the destination chain, resume tracing from that address to follow the leg onward and update the recovery position.

Verification gate

None of the above may be taken on trust. Before any mainnet execution the full batch must be proven on a mainnet fork across all chains, ending in: every maturity lend FV == borrow FV, internal counters consistent, each vault solvent against deposits, the attacker net zero and non-withdrawable, and legitimate user positions matching the expected state. The protocol is unpaused only after that proof holds.

The updated code must not be assumed safe because it targets this incident. The fixed tree logic (`5bb5128`), the temporary remediation function and recovery contract, and the beacon upgrade should each be independently reviewed for new vulnerabilities before deployment - including the temporary privileged path used during the correction - and the temporary function and its permissions removed once the correction is verified.

Conclusions are limited to on-chain data and the deployed source assessed to date.

© 2026 – Quantstamp, Inc. · Secured Finance